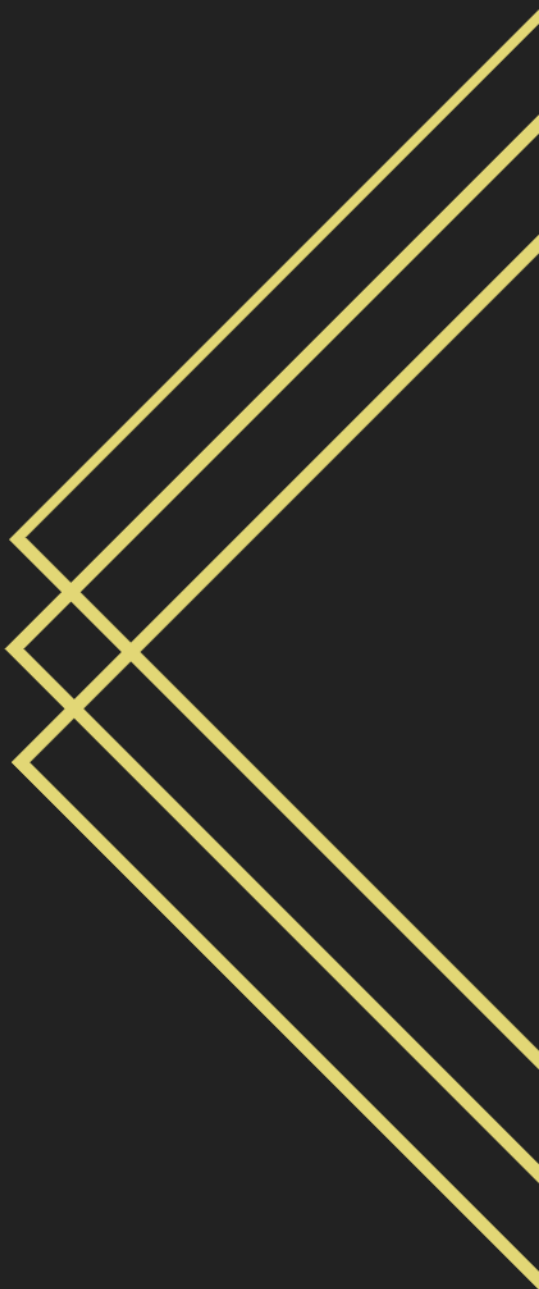


MÓDULO 2 | IAM

MATERIAL COMPLEMENTAR



Identity and Access Management (IAM)

O que é o IAM?

O AWS Identity and Access Management (IAM) é um serviço web que te ajuda a controlar o acesso aos recursos da AWS de forma segura. Você usa o IAM para controlar quem é autenticado (fez login) e autorizado (tem permissões) a usar os recursos.

Recursos

Acesso Compartilhado à sua conta da AWS

Você pode conceder permissão a outras pessoas para administrar e usar recursos em sua conta da AWS sem precisar compartilhar sua senha ou chave de acesso.

Permissões granulares

Você pode conceder permissões diferentes a pessoas diferentes para recursos diferentes. Por exemplo, você pode permitir que alguns usuários tenham acesso completo ao Amazon Elastic Compute Cloud (Amazon EC2), Amazon Simple Storage Service (Amazon S3), Amazon DynamoDB, Amazon Redshift e outros serviços AWS. Para outros usuários, você pode permitir acesso somente leitura a apenas alguns S3 buckets, ou permissão para administrar apenas algumas EC2 instances, ou para acessar suas informações de faturamento mas nada mais.

Acesso seguro a recursos da AWS para aplicativos que são executados no Amazon EC2

Você pode usar os recursos do IAM para fornecer credenciais com segurança para aplicativos executados em EC2 instances. Essas credenciais fornecem permissões para que seu aplicativo acesse outros recursos da AWS. Os exemplos incluem S3 buckets e DynamoDB tables.

Autenticação multifator (MFA)

Você pode adicionar autenticação multifator à sua conta e a usuários individuais para segurança extra. Com o MFA, você ou seus usuários devem fornecer não apenas uma senha ou chave de acesso para trabalhar com sua conta, mas também um código de um dispositivo especialmente configurado.

Federação de identidades

Você pode permitir que usuários que já possuem senhas em outro lugar - por exemplo, em sua rede corporativa ou em um provedor de identidade na Internet - obtenham acesso temporário à sua conta AWS.

Informações de identidade para garantia

Se você usa o AWS CloudTrail, você recebe registros de log que incluem informações sobre quem fez solicitações de recursos em sua conta. Essas informações são baseadas nas IAM Identities.

Informações de identidade para garantia

O IAM suporta o processamento, armazenamento e transmissão de dados de cartão de crédito feito por um comerciante ou provedor de serviços e foi validado como sendo compatível com o Padrão de Segurança de Dados (DSS) da Indústria de Cartões de Pagamento (PCI).

Como funciona o IAM

O IAM fornece a infraestrutura necessária para controlar a autenticação e a autorização de sua conta.

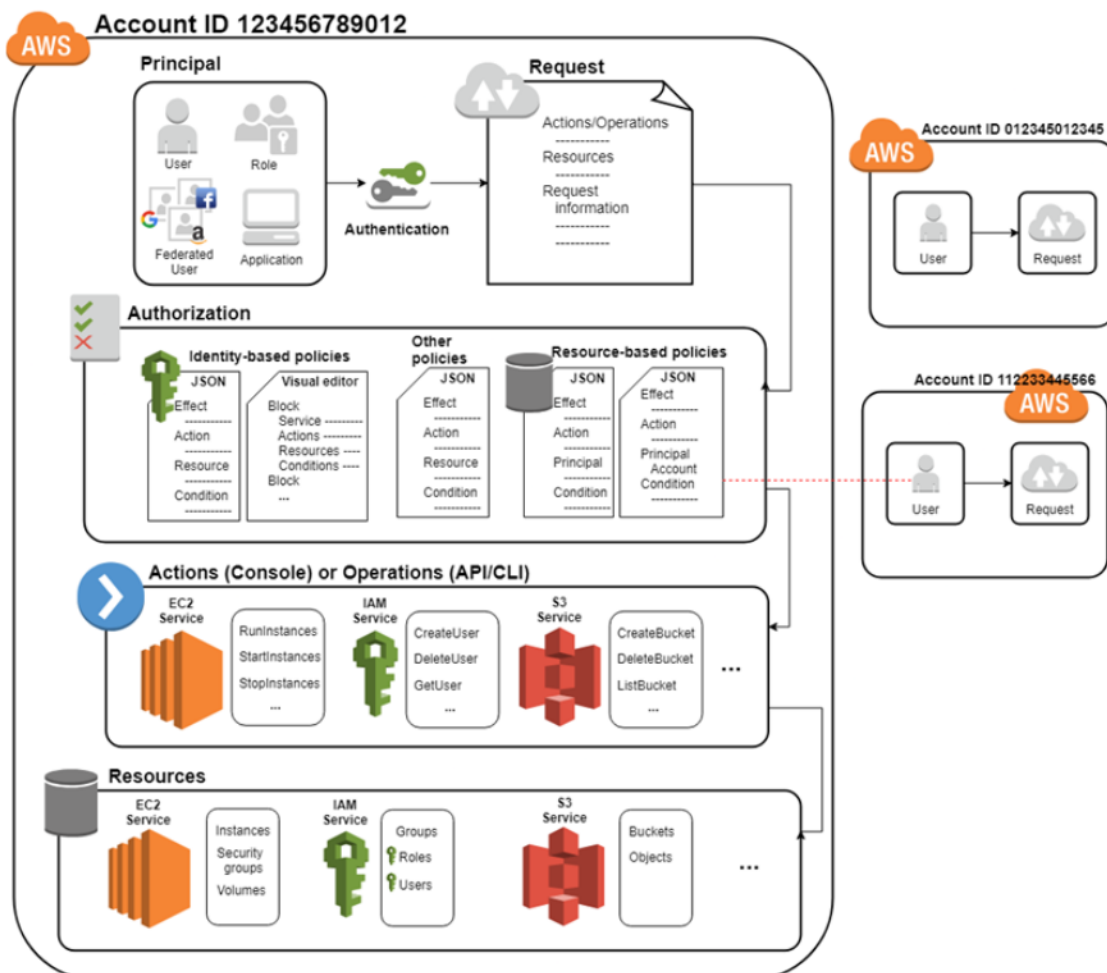


Figura 1 - Fonte: docs.aws.amazon.com

Termos

Resources

Usuário, grupo, função, política, provedor de identidade e objetos que são armazenados no IAM. Assim como em outros serviços da AWS, você pode adicionar, editar e remover recursos do IAM.

Identities

Os objetos de recursos do IAM usados para identificar e agrupar. Você pode anexar uma política a uma identidade IAM. Isso inclui usuários, grupos e funções.

Entities

Os objetos de recursos do IAM que a AWS usa para autenticação. Isso inclui usuários do IAM, usuários federados e funções do IAM assumidas.

Principals

Uma pessoa ou aplicativo que usa o usuário raiz da conta da AWS, um usuário IAM ou uma função IAM para entrar e fazer solicitações à AWS.

Principal

Um *principal* é uma pessoa ou aplicativo que pode fazer uma solicitação para uma ação ou operação em um recurso da AWS. O *principal* é autenticado como o usuário raiz da conta da AWS ou uma IAM *entity* para fazer solicitações à AWS. Como uma melhor prática, não use suas credenciais do usuário root para seu trabalho diário. Em vez disso, crie IAM entities (usuários e funções). Você também pode oferecer suporte a usuários federados ou acesso programático para permitir que um aplicativo acesse sua conta da AWS.

Request

Quando um *principal* tenta usar a AWS Management Console, a AWS API ou a AWS CLI, ele envia uma *solicitação* para a AWS. A solicitação inclui as seguintes informações:

- **Ações (ou operações)** - As ações ou as operações que o principal deseja executar. Pode ser uma ação na AWS Management Console, uma operação na AWS CLI ou na AWS API.
- **Recursos** - O AWS resource object no qual as ações ou operações são executadas.
- **Principal** - A pessoa ou o aplicativo que usou uma entity (usuário ou função) para enviar a solicitação. As informações sobre a principal incluem as políticas associadas à entity usada pelo principal para fazer login.
- **Dados do ambiente** - Informações sobre o endereço IP, o agente do usuário, o status do SSL habilitado ou a hora do dia.
- **Dados do recurso** - Dados relacionados ao recurso que está sendo solicitado. Isso pode incluir informações como o nome da tabela do DynamoDB ou uma tag em uma instância do Amazon EC2.



O AWS reúne as informações da solicitação em um *contexto de solicitação*, que é usado para avaliar e autorizar a solicitação.

Authentication

O principal deve ser autenticado (conectado na AWS) usando suas credenciais para enviar uma solicitação para a AWS. Alguns serviços, como o Amazon S3 e o AWS STS, permitem algumas solicitações de usuários anônimos. No entanto, eles são a exceção à regra.

Para se autenticar na console como um usuário root, você deve fazer login com seu endereço de e-mail e senha. Como um usuário IAM, forneça seu account ID ou alias e, em seguida, seu nome de usuário e senha. Para autenticar a partir da API ou AWS CLI, você deve fornecer sua chave de acesso e a chave secreta. Você também pode ser solicitado a fornecer informações adicionais de segurança. Por exemplo, a AWS recomenda que você use a autenticação multifator (MFA) para aumentar a segurança da sua conta.

Authorization

Você também deve ter autorização (permissão) para concluir sua solicitação. Durante a autorização, a AWS usa valores do contexto da solicitação para verificar as políticas que se aplicam à solicitação. Em seguida, ele usa as políticas para determinar se deve permitir ou negar a solicitação. A maioria das políticas são armazenadas na AWS como documentos JSON e especificam as permissões para principal entities. Existem vários tipos de políticas que podem afetar se uma solicitação é autorizada. Para fornecer aos seus usuários permissões para acessar os recursos da AWS em suas próprias contas, você precisa apenas de políticas baseadas em identidade. As políticas baseadas em recursos são populares por conceder acesso entre contas. Os outros tipos de política são recursos avançados e devem ser usados com cuidado.

A AWS verifica cada política que se aplica ao contexto de sua solicitação. Se uma única política de permissões incluir uma ação negada, a AWS nega toda a solicitação e interrompe a avaliação. Isso é chamado uma *explicit deny*. Como as solicitações são *negadas por padrão*, a AWS autoriza sua solicitação apenas se todas as partes de sua solicitação forem permitidas pelas políticas de permissões aplicáveis. A lógica de avaliação para uma solicitação em uma única conta segue estas regras gerais:

- Por padrão, todas as solicitações são negadas. (Em geral, as solicitações feitas usando as credenciais de usuário root da conta da AWS para recursos na conta são sempre permitidas.)
- Uma permissão explícita em qualquer política de permissões (baseada em identidade ou em recursos) substitui esse padrão.
- A existência de Organizations SCP, IAM permissions boundary, ou uma política de sessão substitui a permissão. Se um ou mais desses tipos de política existir, todos eles devem permitir a solicitação. Caso contrário, é negado implicitamente.
- Uma negação explícita em qualquer política substitui qualquer permissão.



Actions or operations

Depois que sua solicitação for autenticada e autorizada, a AWS aprova as ações ou operações em sua solicitação. As operações são definidas por um serviço e incluem coisas que você pode fazer em um recurso, como visualizar, criar, editar e excluir. Por exemplo, o IAM oferece suporte a aproximadamente 40 ações para um recurso de usuário, incluindo as seguintes ações:

- CreateUser
- DeleteUser
- GetUser
- UpdateUser

Para permitir que um principal execute uma operação, você deve incluir as ações necessárias em uma política que se aplica ao principal ou ao recurso afetado.

Usuário raiz, usuário IAM e Federation

Usuário raiz

Identidade única de login que tem acesso total a todos os recursos da AWS na conta.

Usuário IAM

Identidade única de login que tem AWS Identity and Access Management (IAM) user é uma entidade que é criada para representar uma pessoa ou aplicativo que o usa para interagir com a AWS. Um usuário na AWS consiste em um nome e credenciais. Um usuário IAM com permissões de administrador não é a mesma coisa que o usuário raiz da conta AWS. total a todos os recursos da AWS na conta.

Federation

A federação de identidade é um sistema de confiança entre duas partes com o objetivo de autenticar usuários e transmitir as informações necessárias para autorizar seu acesso aos recursos.



Grupos, Políticas e Permissões

Grupos

Um grupo do IAM é um conjunto de usuários do IAM. Os grupos permitem especificar permissões para vários usuários, o que pode facilitar o gerenciamento das permissões para esses usuários.

Policy

Uma política é um objeto na AWS que, quando associado a uma identidade ou a um recurso, define suas permissões. Por exemplo, se uma política permitir a ação GetUser, um usuário com essa política poderá obter informações de usuários no Console de gerenciamento da AWS, na AWS CLI ou na API da AWS.

Permissões

As permissões nas políticas determinam se a solicitação será permitida ou negada.

Referências e fontes

As imagens e informações técnicas foram extraídas, traduzidas e resumidas com base na documentação pública oficial da Amazon Web Services. Todos os direitos autorais pertencem aos seus respectivos donos.

- * <https://docs.aws.amazon.com/IAM/latest/UserGuide/intro-structure.html>
- * https://docs.aws.amazon.com/pt_br/IAM/latest/UserGuide/best-practices.html
- * https://docs.aws.amazon.com/pt_br/IAM/latest/UserGuide/id_root-user.html
- * https://docs.aws.amazon.com/IAM/latest/UserGuide/id_users.html
- * <https://aws.amazon.com/identity/federation/>
- * <https://docs.aws.amazon.com/IAM/latest/UserGuide/introduction.html>
- * https://docs.aws.amazon.com/pt_br/IAM/latest/UserGuide/id_groups.html
- * https://docs.aws.amazon.com/pt_br/IAM/latest/UserGuide/access_policies.html

